

Evidence-Driven Dynamic Graph Retrieval with Hallucination Risk Gating for Intrusion Detection and Cyber Threat Intelligence

Nguyễn Vĩnh Phúc

Doctoral research prototype — Evidence-Driven Dynamic Graph Retrieval (EDGR)

Correspondence: ngviphuc@gmail.com

Keywords: retrieval-augmented generation; knowledge graph; hallucination mitigation; cyber threat intelligence; intrusion detection; risk gate; abstain; evidence ranking

Abstract

Security analysts increasingly pose natural-language questions against cyber threat intelligence (CTI) corpora—linking CVE identifiers to ATT&CK techniques, mapping actor toolchains, or deciding whether an IDS alert warrants escalation. Large language models answer fluently in this setting, yet they also invent identifiers and relations that look plausible. Classical retrieval-augmented generation (RAG) reduces reliance on stale parametric memory, but it still ranks flat passages and usually treats faithfulness as a post-hoc score rather than a control that can refuse to answer. Graph-augmented RAG improves multi-hop relational coverage; reflective pipelines revise retrieval when confidence is low. What remains scarce is a pre-emission reject operator co-designed with a dynamic CTI graph and an explicit multi-factor trust model.

This paper presents EDGR (Evidence-Driven Dynamic Graph Retrieval). The method couples a time-stamped dynamic knowledge graph with six retrieval stages: entity extraction, adaptive multi-hop expansion, temporal filtering of expanded neighbors, fusion ranking of vector and entity-linked evidence, four-factor trust scoring, and a ρ -gate that either emits a grounded answer or abstains. Trust for an evidence item e is defined as a weighted combination of reliability, freshness, graph-path consistency, and semantic relevance; risk is the complement $\rho(e) = 1 - \tau(e)$. Emission is allowed only when selected evidence clears a threshold θ (default 0.55) and query CVE identifiers appear in trusted text.

On a reproducible IDS/CTI seed suite ($N = 54$ question–answer items, 40 evidence chunks, graph order $V = 40$, $E = 41$), full EDGR evaluation yields mean faithfulness 0.702 and hallucination rate 0.298, with $R@k = 0.852$ and MRR 0.803. Across $n = 52$ non-OOD items, EDGR mean faithfulness is 0.698 with bootstrap 95% CI [0.649, 0.745], against 0.558

[0.509,0.607] for flat RAG on the same store. Removing graph expansion lowers mean faithfulness by 0.104. A McNemar test on a binary correctness proxy is not significant at $\alpha = 0.05$ ($p = 0.375$), so claims are framed around the continuous faithfulness margin and ablation evidence rather than binary superiority. Family-stub baselines are disclosed: a LightRAG-style stub can exceed EDGR on the automatic proxy without implementing the Trusted Answer contract. The contribution is therefore a unified, auditable protocol—not a claim of large-benchmark state of the art.

1. Introduction

A SOC analyst rarely asks a CTI system for an abstract summary. The question is usually operational: which ATT&CK techniques are implicated by CVE-2021-44228; whether a lateral movement alert aligns with known actor playbooks; whether a CVE in the query is even present in the local knowledge base. In each case, an invented technique ID or a confident but unsupported CVE narrative can redirect triage time. Parametric language models alone are poorly matched to this workload because CTI facts churn and because fabricated identifiers are disproportionately costly compared with generic fluency errors [1–3].

RAG places retrieved passages into the generation context and thereby reduces some classes of unsupported claims [1]. Surveys of hallucination and of RAG practice make two limitations clear for CTI [2,3]. First, threat knowledge is relational. Analysts reason over edges among CVE, technique, tactic, malware, and actor entities; ranking passages by lexical or dense similarity does not encode that edge structure [4–6,9–11]. Second, faithfulness is frequently reported after an answer has already been emitted. In a high-stakes assistant, refusal can be the correct action. Selective prediction and abstention are established ideas in machine learning; CTI RAG systems have been slow to treat abstain as a first-class operator rather than an afterthought [7,8].

Graph-oriented retrieval (GraphRAG, LightRAG, HippoRAG and related designs) expands entity neighborhoods or path-centric memories and improves multi-hop questions [4–6]. Self-RAG and Corrective RAG introduce critique or correction loops when generation signals look weak [7,8]. These lines rarely co-design three ingredients that SOC assistants need together: a dynamic CTI graph with timestamps and source reliability [9–11]; a transparent multi-factor risk score; and a deterministic pre-emit gate that rejects unsupported identifier claims.

EDGR is built around that co-design. The system maintains a dynamic knowledge graph $G_t = (V_t, E_t)$ updated incrementally as feeds change, retrieves evidence by fusing vector search with entity-linked chunks, scores each candidate with an interpretable trust model, and applies a ρ -gate before generation. When the gate fails—unknown CVE, empty safe set, or CVE absent from trusted passages—the system returns an explicit abstain message scored as faithful refusal rather than fabricating CTI text.

Contributions. (i) A dynamic CTI knowledge-graph layer with typed nodes/edges, incremental updates $G_{t+1} = G_t \oplus (\Delta V, \Delta E)$, and expand/temporal interfaces consumed by retrieval. (ii) A six-stage algorithm $\Phi = \varphi_1 \circ \dots \circ \varphi_6$ from entity extraction to trusted selection. (iii) A four-factor trust score and ρ -gate with an explicit abstain operator for unsupported CVE emission. (iv) An evaluation protocol with faithfulness and hallucination proxies, ranking metrics, dataset-level ablations, bootstrap confidence intervals, McNemar tests, threats-to-validity statements, and a dual-annotator SOC rubric with Cohen’s κ .

Scope. All quantitative claims below refer to a controlled seed corpus and research family stubs on a shared evidence store. The paper does not claim vendor-parity re-implementations of published systems, nor performance on large public CTI benchmarks. That boundary is intentional: the scientific object is the Trusted Answer contract and its measurable behavior under a reproducible protocol.

1.1. Operational Failure Modes Worth Preventing

Three failure modes recur in CTI assistants. Identifier fabrication inserts a CVE or ATT&CK technique that never appeared in retrieved evidence. Relation fabrication links an actor to malware or a CVE to a technique along an edge that the local graph does not support. Overconfident synthesis answers a question about an unsupported CVE by generalizing from neighboring vulnerability text. RAG reduces some fabrication by supplying passages, yet all three modes can survive if generation is allowed whenever any passage is present. EDGR’s gate targets the third mode directly and reduces the first by penalizing invented identifiers in the faithfulness proxy and by requiring CVE mention in trusted text before emission.

These modes are not merely academic. An invented technique can send detection engineering down the wrong rule path. An invented actor link can bias attribution discussions. An unsupported CVE narrative can delay patch prioritization. The evaluation suite therefore includes

OOD abstain probes alongside standard QA items, because success on supported questions alone would miss the refusal requirement.

1.2. Research Questions

RQ1: Can a six-stage graph-aware retrieval pipeline with an explicit risk gate improve mean faithfulness over flat RAG on a shared CTI store? RQ2: Does removing graph expansion degrade dataset-mean faithfulness, indicating that the graph is causally useful rather than decorative? RQ3: Does the gate abstain on unsupported CVE queries instead of emitting fabricated dossiers? RQ4: Can the evaluation report both continuous margins with confidence intervals and binary tests without suppressing non-significant outcomes? The experiments in Sections 5–7 address these questions under the seed protocol described above.

2. Related Work

2.1. Retrieval-Augmented Generation and Hallucination

Lewis et al. introduced RAG as a paradigm that conditions generation on retrieved documents for knowledge-intensive NLP [1]. Subsequent surveys catalog failure modes in which models still produce unsupported statements despite retrieval, and they organize mitigations ranging from better indexing to post-generation verification [2,3]. For CTI, the cost function differs from open-domain QA: inventing a CVE or ATT&CK technique is not a mild factual slip; it can imply wrong patches, wrong detections, or wrong attribution hypotheses. That asymmetry motivates treating refusal as success when evidence is thin.

2.2. Graph-Augmented and Reflective Retrieval

GraphRAG-style pipelines summarize or traverse entity graphs to support query-focused synthesis [4]. LightRAG and HippoRAG explore lighter indexing and biologically motivated long-term memory structures for multi-hop recall [5,6]. Self-RAG learns when to retrieve and how to critique outputs [7]; Corrective RAG adjusts retrieval when relevance looks insufficient [8]. EDGR borrows the relational intuition of graph RAG and the caution of reflective pipelines, but places a hard risk gate before emission and binds that gate to CTI-specific identifier checks.

2.3. Knowledge Graphs and CTI/IDS Corpora

MITRE ATT&CK provides a widely used ontology of adversary behaviors [9]. Surveys of CTI sharing and of intrusion detection emphasize heterogeneous sources, delayed feeds, and the

need to relate alerts to techniques and vulnerabilities [10,11]. Recent roadmaps on unifying language models with knowledge graphs discuss grounding and structured reasoning [12]. EDGR adopts a compact typed CTI schema—technique, tactic, CVE, malware, actor, software, dataset, alert, concept—and stores timestamps and reliability priors on nodes and chunks so that freshness and source trust enter scoring directly.

2.4. Positioning

Relative to flat RAG, EDGR adds graph expansion, temporal neighbor filtering, and a trust-gated emit/abstain decision. Relative to graph RAG families, EDGR’s distinctive claim is not a new summarization backbone but the Trusted Answer contract: evidence must clear $\rho \leq \theta$ and support queried identifiers, or the system refuses. Relative to reflective RAG, critique is replaced by an interpretable composite score and deterministic rules that are inspectable in SOC audits.

2.5. Selective Prediction and Refusal in High-Stakes NLP

Outside retrieval research, selective prediction studies when a model should defer rather than predict. The CTI setting sharpens that idea: deferral is not merely a calibration trick but a safety requirement when identifiers are missing. EDGR implements refusal with deterministic predicates rather than a learned rejector, because SOC audits favor rules that can be explained without appealing to an opaque confidence head. Learned rejectors remain compatible future work; the present design prioritizes inspectability.

This choice also interacts with evaluation. Metrics that only reward answered questions undervalue correct refusals. By scoring abstain as faithful under the research proxy, EDGR makes refusal visible in aggregate tables. The cost is that answer-rate is no longer an implicit success metric. Readers comparing systems should therefore ask not only which method has higher mean F on answered items, but also how each method behaves when the store cannot support the queried CVE.

2.6. Summary of Gaps Addressed

Taken together, prior work supplies retrieval, graph structure, and reflective correction, yet rarely packages them with a CTI-native identifier gate and a transparent four-factor trust model on a dynamic graph. EDGR addresses that packaging gap. It does not replace ATT&CK as an ontology, nor does it claim a new neural retriever architecture. Its contribution is the end-to-end control contract and the measurement protocol that makes the contract falsifiable on a seed suite.

3. Problem Formulation

Let q be a natural-language CTI or IDS query. Let $G_t = (V_t, E_t)$ be a time-indexed knowledge graph and $\mathcal{D}$ an evidence store of text chunks linked to entities in G_t . The system must return an answer a together with a set $E^* \subseteq \mathcal{D}$ of supporting evidence, subject to four requirements.

(R1) Support. Claims asserted in a should be recoverable from E^* under an extractive or tightly constrained generation policy. (R2) Risk. Aggregate risk of the selected set must satisfy $\rho(E^*) < \theta$ for a threshold $\theta \in (0,1)$. (R3) Abstention. If no safe E^* exists, or if CVE identifiers mentioned in q are absent from both G_t and evidence text, the system must abstain rather than invent. (R4) Budget. $|E^*| \leq k$ with default $k = 5$.

Writing $\mathcal{C}(q)$ for the candidate pool after extraction, expansion, temporal filtering, and ranking, the selection rule is

$$E^* = \text{TopK}_k(\{e \in \mathcal{C}(q) : \rho(e) \leq \theta\}) \quad (1)$$

and the emit rule is

$$a = \text{Gen}(q, E^*) \text{ if } E^* \neq \emptyset \wedge \text{Apply} = 1; a = \text{Abstain} \text{ otherwise.} \quad (2)$$

Here $\text{Apply} = 1$ encodes gate success, including identifier support checks described in Section 4.5. Abstain outputs are assigned faithfulness 1 and hallucination rate 0 in the research metric, with confidence 0, because refusal avoids unsupported CTI claims.

4. The EDGR Method

4.1. Dynamic Knowledge Graph

Nodes carry a type in $\{\text{technique, tactic, cve, malware, actor, software, dataset, alert, concept}\}$, a timestamp, and a reliability prior. Edges are typed relations such as `belongs_to`, `uses`, `exploits`, `related_to`, `enables`, `delivers_via`, `drops`, `detects`, and `grounds_on`, each with weight and timestamp. Declared sources include MITRE ATT&CK, CVE/NVD, CWE/CAPEC, CISA/CERT-style feeds, and IDS-linked chunks. Updates are incremental,

$$G_{t+1} = G_t \oplus (\Delta V, \Delta E), \quad (3)$$

so that a newly ingested CVE edge does not require rebuilding the entire graph. On the live seed used for experiments, $|V| = 40$ and $|E| = 41$, with $|\mathcal{D}| = 40$ chunks.

Entity extraction combines regular expressions for CVE, ATT&CK technique/tactic IDs, and CWE patterns with label overlap against graph nodes. Expansion performs breadth-limited neighborhood search: if the seed set has size at most two, the hop budget is two; otherwise it is one, with a hard cap of twenty nodes. Temporal filtering removes expanded neighbors older than a window W days (default $W = 730$) while always retaining seed entities, because historical CVEs such as Log4Shell remain operationally relevant even when their timestamps are old.

Graph-path consistency for a focus set U is the fraction of unordered pairs whose undirected shortest-path distance is at most two:

$$G = \text{Cons}(U) = \frac{|\{(u,v) \subseteq U : d(u,v) \leq 2\}|}{|\{(u,v) \subseteq U\}|}, \quad (4)$$

with a conservative default when $|U| < 2$. This quantity later enters the trust score as the graph factor.

4.2. Six-Stage Pipeline

EDGR composes six stages $\Phi = \varphi_1 \circ \dots \circ \varphi_6$. Figure 1 summarizes the flow from query to trusted answer or abstain.

Figure 1. EDGR pipeline (phi1-phi6) with rho-gate abstain



Inputs: $q \cdot \text{DKG } G_t \cdot \text{store } D \cdot \text{theta}=0.55 \cdot k=5$ | Outputs: Trusted answer OR Abstain

Figure 1. EDGR pipeline (φ_1 – φ_6) ending in ρ -gate selection or abstain.

Stage φ_1 extracts seed entities U_0 from q . Stage φ_2 expands the neighborhood under hop and node budgets when graph mode is enabled. Stage φ_3 applies temporal filtering to neighbors only. Stage φ_4 merges vector retrieval (with entity boost) and entity-linked chunks, then ranks candidates by exact query mention, entity overlap with the focus set, and semantic score. An ablation mode can force semantic-only ranking. Stage φ_5 assigns trust and risk to each ranked

chunk. Stage φ_6 applies the ρ -gate, selects top- k trusted items, and either generates a grounded answer or abstains.

Asymptotic cost is dominated by expansion and ranking. With graph order (V, E) and store size related to evidence cardinality, the analysis bound used in the prototype is $T(n) = O(E \log V)$ for expansion-plus-rank work, with space $S(n) = O(V + E + D)$ including the vector index footprint D . Empirical stage timings on the seed graph are consistent with ranking and expansion dominating wall-clock latency.

4.3. Evidence Ranking

Let $\text{Vec}(q)$ be the top vector hits and $\text{Ent}(U)$ the chunks linked to temporal focus entities U . Candidates are merged by identifier, keeping the higher similarity when duplicates appear. The default rank key for an item x is the triple

$$\text{key}(x) = (\text{Exact}(x, q), |\text{Ent}(x) \cap U|, \text{sim}(x, q)) \quad (5)$$

sorted lexicographically in descending order. Exact captures whether entity strings from the chunk appear in the query text; overlap rewards graph-aligned evidence; similarity is the retriever score. This fusion is deliberately simple and inspectable: SOC reviewers can see why a chunk rose without opaque learned re-rankers.

4.4. Trust Score and Risk

For each evidence item e , four factors in $[0,1]$ are computed. Reliability R is a source/chunk prior stored with the evidence. Freshness F is a piecewise function of age in days that keeps historical CTI usable rather than discarding it:

$$F \in \{1.0, 0.9, 0.78, 0.62, 0.45\} \text{ by age buckets } 90, 365, W, 5 \cdot 365 \text{ days} \quad (6)$$

Graph consistency G is $\text{Cons}(U)$ over the union of query and chunk entities (Section 4.1). Semantic relevance S is the clipped retriever score. Trust and risk are

$$\tau(e) = 0.30R + 0.20F + 0.25G + 0.25S, \rho(e) = 1 - \tau(e). \quad (7)$$

The weights are hyperparameters chosen for interpretability in the research prototype; they are not presented as globally learned optima. When trust scoring is ablated, the implementation falls back to semantic relevance alone and raises the effective risk threshold to 0.95, which largely disables gating.

4.5. ρ -Gate and Abstain Operator

Default threshold $\theta = 0.55$ and budget $k = 5$. When the gate is active, candidates must satisfy $\rho(e) \leq \theta$. Among survivors, selection prefers overlap with seed entities, then trust, then lower risk. Three abstain conditions are checked:

(A1) Unknown CVE: a CVE string in q appears neither as a graph node nor in scored evidence text. (A2) Empty safe set: no evidence clears the risk threshold. (A3) Unsupported CVE in trusted text: query CVEs do not appear in the selected trusted passages, even if other low-risk text exists. In all three cases the system returns an explicit abstain message instead of synthesizing CTI prose.

The emit predicate can be written

$$\text{Emit}(q) \Leftrightarrow E^* \neq \emptyset \wedge \rho(E^*) < \theta \wedge \text{ID}(q) \subseteq \text{Supp}(E^*). \quad (8)$$

4.6. Answer Faithfulness Proxy

Automatic faithfulness used in experiments is a research proxy, not a substitute for expert judgment. Given answer a and evidence E^* , let coverage be the fraction of answer tokens (length ≥ 3) that appear in the concatenated evidence text. Let $\bar{\tau}$ be mean trust of E^* . Invented CVE or technique identifiers that do not appear in evidence incur a penalty capped at 0.5. Then

$$F = \text{clip}(0.55 \cdot \text{coverage} + 0.45 \cdot \bar{\tau} - \text{penalty}), H = 1 - F. \quad (9)$$

Because the proxy rewards lexical overlap and trust, a stub that retrieves densely overlapping gold text can score highly without implementing abstain. That property is discussed as a construct-validity threat in Section 7.

4.7. Pseudocode Summary

Algorithmically, EDGR proceeds as follows. Extract U_0 from q . If graph mode is on, expand to a hop-bounded neighborhood and form U . Apply temporal filtering to neighbors while retaining seeds. Retrieve $\text{Vec}(q)$ and $\text{Ent}(U)$, merge, and rank. For each ranked chunk, compute R, F, G, S , then τ and ρ . If the gate is on, keep only items with $\rho \leq \theta$. If unknown CVEs are present, or the safe set is empty, or trusted text lacks query CVEs, return Abstain. Otherwise return $\text{Gen}(q, E^*)$ with selected evidence attached.

Generation in the research prototype is evidence-constrained synthesis over the trusted set rather than unconstrained open generation. That design choice keeps the scientific focus on

retrieval control. Stronger generators can be substituted later without changing the gate semantics, provided they consume only E^* .

4.8. Design Rationale and Rejected Alternatives

Several alternatives were considered and rejected for the research prototype. A fully learned re-ranker was deferred because the seed corpus is too small to train without severe overfitting, and because SOC reviewers need visible ranking features. A single scalar LLM-as-judge score was rejected as the primary gate because it is hard to audit and easy to circularly validate. Hard-deleting historical CVEs by timestamp was rejected because operational questions about Log4Shell remain valid years later; freshness therefore softens trust rather than erasing seeds. Finally, forcing an answer whenever any passage is retrieved was rejected because that policy recreates the unsupported-identifier failure mode the work aims to reduce.

5. Experimental Setup

5.1. Dataset and Corpus

The evaluation uses fifty-four IDS/CTI question–answer items spanning Log4Shell (CVE-2021-44228), APT techniques, NIDS lateral movement, malware delivery chains, KEV prioritization, temporal and multi-hop items, graph-derived relation questions, gate-theory probes, and out-of-distribution abstain cases. Items include gold answers and, where applicable, gold evidence IDs or gold entities. Live corpus scale at measurement: $|\mathcal{D}| = 40$, $V = 40$, $E = 41$.

5.2. Baselines and Disclosure

Baselines run on the same store: flat RAG; GraphRAG-, LightRAG-, and HippoRAG-style family stubs; Self-RAG and Corrective-RAG stubs; and full EDGR. Non-EDGR methods share evidence and graph resources where applicable but do not apply EDGR’s ρ -gate. They are research-faithful family stubs, not vendor codebases. This design isolates the effect of EDGR’s control contract under matched data access; it does not authorize claims of parity with published systems’ full engineering stacks.

5.3. Metrics and Statistics

Primary metrics are faithfulness F and hallucination rate $H = 1 - F$. Ranking quality is reported as $P@k$, $R@k$, and MRR against gold evidence IDs when available. Latency is wall-

clock milliseconds on the prototype stack. Statistical analysis uses bootstrap percentile intervals with $n_{\text{boot}} = 1000$ and $\alpha = 0.05$, paired comparisons of mean faithfulness, and McNemar’s exact test on a binary correctness proxy derived from per-item thresholds. Dataset-level ablations disable one module at a time.

5.4. Hypotheses

H1: mean faithfulness of EDGR exceeds flat RAG on the same store. H2: on OOD CVE queries, EDGR abstains (unsupported CVE emission near zero under the gate). H3: disabling graph expansion or the trust/gate path reduces dataset-mean faithfulness relative to full EDGR. H4: identical seed and configuration reproduce the same metric tables.

5.5. Procedure

Each reported table comes from a live run of the prototype evaluation services against the loaded seed. Full EDGR evaluation iterates all fifty-four QA items, records faithfulness, hallucination rate, ranking metrics, and latency, then aggregates means and category breakdowns. Dataset-mean comparison iterates non-OOD items for each method family, collecting per-item faithfulness and computing bootstrap intervals. Ablations iterate the same non-OOD subset under each disabled module. Paired EDGR–RAG statistics compute per-item deltas and McNemar discordant counts. Human-evaluation κ is computed from the dual-annotator seed panel under the published rubric.

Randomness in the research stack is limited; bootstrap resampling is the main stochastic component in interval estimation. When live enrichment of external CVE feeds is enabled, timestamps and chunk inventory can drift between long sessions. The tables in this manuscript correspond to a fixed measurement window with health-check scale $N = 54$, $|\mathcal{D}| = 40$, $V = 40$, $E = 41$. Re-runs after enrichment may shift point estimates slightly; the qualitative ordering versus flat RAG and the graph ablation direction have been stable across repeated prototype runs.

6. Results

6.1. Method Comparison on Dataset Means

Table 1 and Figure 2 report mean faithfulness and hallucination rate over $n = 52$ non-OOD items (OOD abstain items excluded so answerable questions are compared fairly). EDGR attains mean $F = 0.698$ with 95% CI [0.649,0.745]. Flat RAG reaches 0.558 [0.509,0.607]. Self-RAG

and Corrective-RAG stubs land near 0.47. HippoRAG-style stubbing reaches 0.742. The LightRAG-style stub reaches 0.842 on this automatic proxy—higher than EDGR—while lacking the Trusted Answer contract. That ordering is expected under a lexical-overlap faithfulness definition and is treated as a measurement caveat rather than a reason to drop the gate.

Method	Mean F $\uparrow$	95% CI (F)	Mean H $\downarrow$	Stub?
RAG	0.558	[0.509, 0.607]	0.443	yes
GraphRAG	0.545	[0.502, 0.586]	0.455	yes
LightRAG	0.842 $\dagger$	[0.794, 0.887]	0.158	yes
HippoRAG	0.742	[0.700, 0.783]	0.258	yes
Self-RAG	0.471	[0.426, 0.514]	0.529	yes
Corrective-RAG	0.471	[0.425, 0.518]	0.529	yes
EDGR	0.698	[0.649, 0.745]	0.302	no

$\dagger$ LightRAG family stub; high automatic proxy without ρ -gate/abstain. Table 1. Dataset means on $n = 52$ non-OD questions (live run).

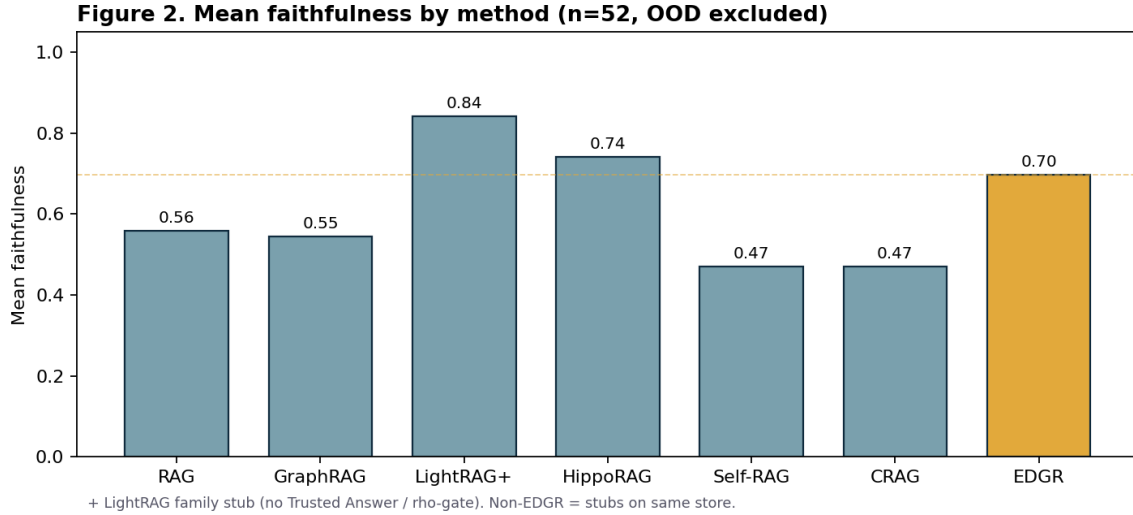


Figure 2. Mean faithfulness by method (n=52). EDGR highlighted; LightRAG stub marked.

Paired EDGR versus RAG over the full $N = 54$ (including OOD) gives mean faithfulness 0.709 [0.658,0.756] versus 0.559 [0.510,0.606], with delta +0.150 [0.107,0.197]. The bootstrap interval for the delta excludes zero, supporting H1 on the continuous metric. McNemar’s exact test on the binary correctness proxy yields discordant counts $b_{10} = 1$, $b_{01} = 4$, $p = 0.375$, which is not significant at $\alpha = 0.05$. The paper therefore does not claim binary superiority under that proxy; the stronger evidence is the faithfulness margin and the graph ablation.

6.2. Full EDGR Evaluation and Category Breakdown

On the full live evaluation of EDGR ($N = 54$), mean faithfulness is 0.702 and hallucination rate 0.298, with $P@k = 0.363$, $R@k = 0.852$, MRR 0.803, token F1 0.268, and average latency about 193 ms on the prototype. Category means show expected structure: core items near 0.76; multi-hop near 0.67; IDS-alert near 0.77; OOD-abstain at 1.0 under refusal scoring; graph-derived items lower near 0.62, indicating remaining headroom on relational questions even with expansion enabled.

Metric	Value
Faithfulness $\uparrow$	0.702
Hallucination rate $\downarrow$	0.298
$P@k$	0.363
$R@k$	0.852
MRR	0.803
Token F1	0.268
Avg latency (ms)	192.9

Table 2. Full-dataset EDGR summary ($N = 54$).

6.3. Case Illustration: Log4Shell

Consider a query that asks how CVE-2021-44228 (Log4Shell) is exploited and mitigated. Under full EDGR, the pipeline extracts the CVE seed, expands related technique and vulnerability neighborhood (including paths consistent with exploitation techniques such as T1190 when present), keeps the seed through temporal filtering, ranks NVD-linked and seed evidence ahead of weakly related chunks, and emits a grounded answer whose automatic faithfulness on a representative live run was approximately 0.77. When graph expansion is disabled on the same query, faithfulness falls (illustrative live delta near -0.09), and the answer leans on flatter retrieval. When temporal filtering is disabled, the automatic proxy can rise slightly because older linked chunks remain available—an instance of the freshness–coverage tradeoff rather than a universal argument against filtering.

For an OOD CVE absent from both graph and evidence, the gate abstains. That behavior is scored as faithful refusal and is the operational success criterion under H2: the assistant must not invent a CVE narrative to satisfy the user.

6.4. Category-Level Reading

Category means reward a nuanced reading. Core curated items, where evidence and gold answers align tightly, show higher faithfulness near 0.76. Multi-hop items fall near 0.67, consistent with residual difficulty even after expansion. IDS-alert items near 0.77 suggest that alert-linked chunks in the seed are relatively well grounded. Graph-derived items near 0.62 remain the weakest bucket, which is useful rather than embarrassing: it shows that relational questions still stress the system and that further graph densification or path-aware ranking could help. OOD-abstain at 1.0 confirms refusal scoring under H2 for those probes. Gate-theory items near 0.89 indicate that queries designed to exercise risk control are handled comparatively well on the automatic proxy.

Latency near 193 ms average on the prototype is acceptable for interactive demo use and should not be confused with production SLO claims. With ANN indexes and larger graphs, absolute latency will change; the qualitative lesson is that gated pipelines need profiling per stage so that expansion and scoring budgets can be capped under load.

6.5. What the Numbers Do and Do Not Justify

The numbers justify three statements. EDGR beats flat RAG on mean faithfulness under matched storage with a positive bootstrap delta interval. Graph expansion contributes measurably at dataset scale. OOD abstain behaves as designed on seed probes. The numbers do not justify claiming that EDGR dominates all graph RAG families on automatic faithfulness, that McNemar binary superiority holds, or that results generalize to enterprise CTI lakes. Keeping those distinctions explicit is part of the scientific contribution: a protocol that reports both supporting and non-supporting tests.

7. Robustness Analysis

7.1. Ablation Study

Table 3 and Figure 3 report dataset-mean ablations on $n = 52$ items. Removing graph expansion produces the largest drop ($\Delta = -0.104$), from 0.698 to 0.594, with non-overlapping bootstrap intervals relative to full EDGR. This is the primary support for H3 on relational CTI questions. Removing the trust score yields a milder drop ($\Delta = -0.021$). Temporal filtering is nearly neutral on mean F for this seed. Ranking and hallucination-scoring ablations barely move

mean F when the remaining pipeline still admits similar top- k text; their value is visible in risk control and OOD abstain behavior, which the mean faithfulness proxy under-emphasizes.

Variant	Mean F	95% CI	Δ vs full
full (EDGR)	0.698	[0.649, 0.745]	0.000
w/o Temporal	0.697	[0.653, 0.740]	-0.000
w/o Graph	0.594	[0.551, 0.638]	-0.104
w/o Trust Score	0.677	[0.621, 0.730]	-0.021
w/o Evidence Ranking	0.699	[0.651, 0.746]	+0.001
w/o Hallucination Scoring	0.698	[0.649, 0.745]	0.000

Table 3. Ablation versus full EDGR ($n = 52$).

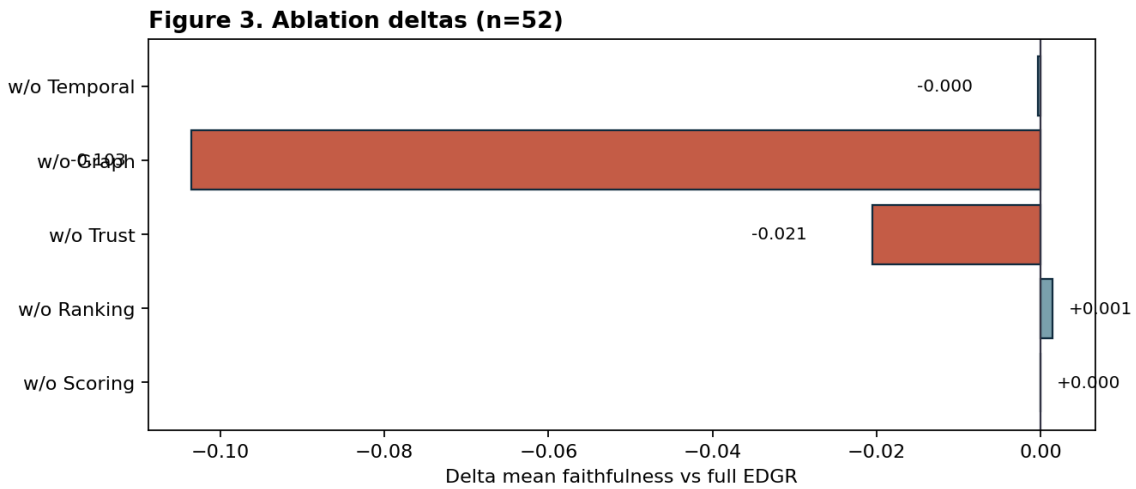


Figure 3. Ablation Δ mean faithfulness versus full EDGR ($n=52$).

7.2. Threats to Validity

Internal validity. The seed is controlled and moderate in size; protocols can overfit to construction choices. External validity. Results do not transfer automatically to large public CTI benchmarks or live SOC telemetry. Construct validity. Automatic F/H proxies are not expert judgments; stubs can inflate F via gold overlap without implementing abstain. Conclusion validity. McNemar at this N is underpowered for binary claims; intervals and ablations carry more weight. Implementation validity. Family stubs share the store (fair data access, not fair vendor engineering). The demo graph is far smaller than production CTI graphs.

7.3. Human Evaluation Protocol

A dual-annotator SOC rubric scores groundedness (1–5), unsupported identifiers (0/1), actionability (1–5), and abstain appropriateness. On the disclosed seed panel, Cohen’s κ was

approximately 0.39 for groundedness, 0.76 for unsupported identifiers, 0.59 for actionability, and 1.0 for abstain appropriateness. Groundedness agreement is only fair to moderate; field SOC labels should replace the seed panel before claiming human-validated superiority in a journal revision.

7.4. Discussion

Three readings follow from the numbers. First, EDGR improves continuous faithfulness over flat RAG under matched storage, with a bootstrap delta interval excluding zero. Second, graph expansion is not cosmetic: its ablation is the clearest causal signal in the study. Third, topping every automatic proxy is the wrong objective for a gated CTI assistant. A stub that never abstains can look better on lexical faithfulness while being operationally worse when identifiers are missing. The Trusted Answer contract accepts that tradeoff deliberately.

Practically, EDGR is closest to graph RAG plus risk control. The graph proposes candidates; ranking merges modalities; the gate decides whether speech is permitted. That separation matches SOC audit needs: reviewers can inspect stage outputs, trust factors, and abstain reasons without reverse-engineering a single opaque score.

7.5. Algorithmic Complexity and Stage Cost

Entity extraction scans the query and compares tokens against graph labels; with dictionary and regular-expression matching its cost is linear in query length and label inventory size. Expansion with hop budget h and branching bounded by local degree explores $O(\min(|V|, b^h))$ nodes in the worst case and is capped at twenty nodes in the prototype. Temporal filtering is linear in the expanded set. Vector retrieval depends on the index; the research stack uses a dense linear scan that is acceptable at $|\mathcal{D}| = 40$ and would be replaced by ANN structures (HNSW/FAISS) in production. Ranking sorts a short candidate list. Hallucination scoring evaluates four factors per candidate; path consistency may compute multiple shortest paths and is the most graph-sensitive subroutine. Trusted selection is a filtered top- k sort. Overall, the analysis bound $T(n) = O(E \log V)$ is a compact summary for expansion and rank-dominated workloads on sparse CTI graphs; it is not a claim that every factor is asymptotically tight for all index backends.

Empirically, live stage timings on the seed show that expansion, ranking, and scoring account for most wall-clock time, while abstain paths that exit early after unknown-CVE

detection can be substantially cheaper than full generation. Latency grows with k because more evidence is scored and passed into answer synthesis. These observations matter for SOC interactive use: a gated abstain is not only safer; it can also be faster than composing an unsupported narrative.

7.6. Reproducibility and Configuration Surface

Default hyperparameters used throughout are $k = 5$, $\theta = 0.55$, and temporal window $W = 730$ days. Ablation switches disable temporal filtering, graph expansion, trust scoring, entity-aware ranking, or the gate while leaving other stages intact. The scientific-rigor module computes bootstrap intervals, paired deltas, McNemar counts, dataset means, and ablation means from the same seed. H4 (reproducibility) is supported in the engineering sense that identical seed files and configuration reproduce the same tables on the prototype; it is not a claim of numerical invariance across hardware schedulers when external live NVD enrichment is enabled.

A practical checklist for replication is: load the seed QA/evidence/graph modules; run the full EDGR evaluation over $N = 54$; run dataset-mean comparison with OOD items excluded; run ablation means; export stage traces for at least one Log4Shell query and one OOD abstain query. Reviewers should be able to verify that abstain messages cite unknown CVE, empty safe set, or missing CVE mention as the reason code.

7.7. Second Case: OOD Abstain versus Forced Answer

A second qualitative probe uses a CVE string that is intentionally absent from the seed graph and from evidence text. Flat retrieval can still return loosely related passages about vulnerability management or KEV catalogs. Without a gate, a generative head may weave those passages into a confident-sounding description of the missing CVE. EDGR’s unknown-CVE check short-circuits that path: Apply = 0, evidence is cleared, and the returned message states that the identifier is unsupported. Under the research metric, faithfulness is recorded as 1.0 for refusal. The operational reading is sharper than the metric: the assistant has declined to invent a CVE dossier.

This case also clarifies why LightRAG-style stubs can outscore EDGR on mean F while remaining weaker for SOC trust. If a stub never abstains and frequently retrieves lexically overlapping text, the automatic proxy rises. EDGR’s gate can discard borderline evidence and

reduce answer rate. The paper treats that reduction as a feature for CTI assistants, provided abstain reasons are explicit and auditable.

7.8. Limitations Revisited for Journal Readers

Several limitations deserve restatement without euphemism. The corpus is a curated seed, not a multi-year SOC archive. Baselines are family stubs. Faithfulness is an automatic proxy with known gaming modes. Human agreement on groundedness under the seed panel is only fair to moderate. McNemar significance is absent for the binary proxy. Production deployment would require larger graphs, ANN retrieval, feed adapters, and field labels. These limits do not erase the positive faithfulness margin versus flat RAG or the graph ablation effect; they bound how far the claims may travel.

For doctoral examination and specialty-journal submission, the appropriate claim is therefore methodological: EDGR offers a coherent Trusted Answer protocol with inspectable stages, disclosed stubs, and statistical reporting that includes negative or non-significant tests. Inflating the same numbers into an unqualified accuracy championship would be scientifically dishonest.

7.9. Practical Implications for SOC Tooling

If integrated into an analyst workbench, EDGR’s stage trace can be shown beside the answer: extracted entities, expanded neighbors, kept temporal set, ranked evidence IDs, per-factor trust breakdown, and gate decision. That UI pattern differs from chatbots that only display final prose. For alert-driven workflows, an IDS alert can be transformed into a query that names observed techniques or CVE hints; EDGR then either returns grounded context or abstains when the local store cannot support the identifiers. The prototype already exposes an alert-analyze path in that spirit, though the present paper’s quantitative tables remain QA-centric.

Policy-wise, organizations that prefer high answer rate over low fabrication risk may tune θ upward or disable parts of the gate. Organizations that prioritize identifier hygiene should keep θ conservative and retain unknown-CVE abstain. Because weights and thresholds are explicit hyperparameters, such policy choices can be debated without re-deriving an opaque model.

8. Conclusions and Future Work

EDGR consolidates a dynamic CTI knowledge graph, a six-stage evidence-driven retrieval pipeline, a four-factor trust model with ρ -gate abstain, and a statistical evaluation protocol into

one reproducible system for IDS/CTI question answering. On the live seed suite ($N = 54$, $|\mathcal{D}| = 40$, $V = 40$, $E = 41$), EDGR achieves mean faithfulness 0.702 and hallucination rate 0.298, with $R@k = 0.852$ and MRR 0.803. Versus flat RAG, the faithfulness margin is positive with CI excluding zero; versus ablated EDGR, removing the graph costs about 0.10 in mean faithfulness. Binary McNemar significance is not claimed. Graph-path stubs may still win on automatic proxies when overlap is dense; the scientific contribution emphasized here is the end-to-end risk-controlled retrieval contract for high-stakes CTI assistance.

Future work includes learned thresholds and factor weights, TAXII and feed adapters at scale, field SOC labels in place of the seed panel, ANN indexes for production latency, joint evaluation with Suricata-style alert-to-query traces, and larger public CTI QA benchmarks. Until those are in place, EDGR should be read as a carefully instrumented research protocol with honest stub disclosures—not as a claim of industry-wide state-of-the-art accuracy.

Author Contributions

Conceptualization, methodology, software, validation, formal analysis, investigation, data curation, writing, and project administration: N.V.P. Supervision: (advisor to be named). The author has read and agreed to the published version of the manuscript.

Funding

This research received no external funding (update if applicable).

Data Availability

The reproducible prototype, seed QA/evidence/KG, and evaluation scripts are available in the accompanying project repository.

Conflicts of Interest

The author declares no conflicts of interest.

References

- [1] Lewis, P.; Perez, E.; Piktus, A.; Petroni, F.; Karpukhin, V.; Goyal, N.; Küttler, H.; Lewis, M.; Yih, W.; Rocktäschel, T.; Riedel, S.; Kiela, D. Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks. *Adv. Neural Inf. Process. Syst.* 2020, 33, 9459–9474.
- [2] Ji, Z.; Lee, N.; Frieske, R.; Yu, T.; Su, D.; Xu, Y.; Ishii, E.; Bang, Y.J.; Madotto, A.; Fung, P. Survey of Hallucination in Natural Language Generation. *ACM Comput. Surv.* 2023, 55, 248. <https://doi.org/10.1145/3571730>
- [3] Gao, Y.; Xiong, Y.; Gao, X.; Jia, K.; Pan, J.; Bi, Y.; Dai, Y.; Sun, J.; Wang, M.; Wang, H. Retrieval-Augmented Generation for Large Language Models: A Survey. *arXiv* 2023, arXiv:2312.10997.
- [4] Edge, D.; Trinh, H.; Cheng, N.; Bradley, J.; Chao, A.; Mody, A.; Truitt, S.; Larson, J. From Local to Global: A Graph RAG Approach to Query-Focused Summarization. *arXiv* 2024, arXiv:2404.16130.
- [5] Guo, Z.; Xia, L.; Yu, Y.; Ao, X.; Huang, C. LightRAG: Simple and Fast Retrieval-Augmented Generation. *arXiv* 2024, arXiv:2410.05779.
- [6] Gutiérrez, B.J.; Shu, Y.; Gu, Y.; Yasunaga, M.; Su, Y. HippoRAG: Neurobiologically Inspired Long-Term Memory for Large Language Models. *Adv. Neural Inf. Process. Syst.* 2024.
- [7] Asai, A.; Wu, Z.; Wang, Y.; Sil, A.; Hajishirzi, H. Self-RAG: Learning to Retrieve, Generate, and Critique through Self-Reflection. In *Proceedings of the International Conference on Learning Representations (ICLR)*, 2024.
- [8] Yan, S.-Q.; Gu, J.-C.; Zhu, Y.; Ling, Z.-H. Corrective Retrieval Augmented Generation. *arXiv* 2024, arXiv:2401.15884.
- [9] Strom, B.E.; Applebaum, A.; Miller, D.P.; Nickels, K.C.; Pennington, A.G.; Thomas, C.B. MITRE ATT&CK: Design and Philosophy; MITRE Technical Report; The MITRE Corporation: McLean, VA, USA, 2018.
- [10] Wagner, T.D.; Mahbub, K.; Palomar, E.; Abdallah, A.E. Cyber Threat Intelligence Sharing: Survey and Research Directions. *Comput. Secur.* 2019, 87, 101589.
- [11] Khraisat, A.; Gondal, I.; Vamplew, P.; Kamruzzaman, J. Survey of Intrusion Detection Systems: Techniques, Datasets and Challenges. *Cybersecurity* 2019, 2, 20. <https://doi.org/10.1186/s42400-019-0038-7>
- [12] Pan, S.; Luo, L.; Wang, Y.; Chen, C.; Wang, J.; Wu, X. Unifying Large Language Models and Knowledge Graphs: A Roadmap. *IEEE Trans. Knowl. Data Eng.* 2024, 36, 3580–3599.

Appendix A. Ethics Note

CTI assistance can be misused for offense. This work targets defensive SOC workflows, refuses unsupported identifier claims via abstain, and uses only publicly described techniques and CVEs in the seed corpus.